

ASSUMPTION (What we believe is true)

The URLs passed to this proxy will only be external, legitimate URLs

ECR is private by default and only authorized AWS accounts can access it

Only the legitimate Forgeate task uses the Task Role creds

Tasks auto run on the latest patched platform version

WHAT BREAKS IT? (Misalignment / Violation)

Attacker sends the internal metadata url 169.254.170.2 - the proxy fetches it from inside the container - thinking its a normal request

Stolen creds from another service gives attacker valid AWS creds

SSRF vulnerability in the app allows attacker to hit the metadata endpoint to steal the active creds

Tasks pinned to old platform versions or long running tasks that haven't been restarted stay on vulnerable runtime

RESULTING BEHAVIOR (What actually happens)

Metadata endpoint returns Task Role creds to the attacker

Attacker pulls container images - sees source code, finds hardcoded secrets, finds vulnerabilities in the image

Attacker uses stolen creds from outside - AWS can't tell the difference from legitimate task activity

Attacker exploits known vulnerabilities in the old platform version - kernel exploits, container escapes

IMPACT (Risk / Consequence)

Attacker can steal the active creds for the task role

Attacker can look at the images and find vulnerabilities to get info to steal secrets

Access to the AWS services that the Task Role permits

Use the vulnerability to escape the container, escalate privileges, or access other containers running on the same host

could be critical dependant on permissions
Major risk, significant damage



HIGH

Severe, likely catastrophic



CRITICAL

Major risk, significant damage



HIGH

Major risk, significant damage



HIGH